

《信息安全》第十讲

操作系统安全

Part I 操作系统安全的一般性原理

2023年11月20日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

容错技术
的概念

容错
技术体系

容错应用

如何直面“剪不断，理还乱”的“故障”

安全操作系统“中国梦”

中央网络安全和信息化领导小组

成立时间: 2014年2月27日

组长



习近平

在北京召开的第一次会议，提出要从国际国内大势出发，总体布局，统筹各方，创新发展，努力把我国建设成为**网络强国**。

网络强国方略是本世纪中国提出的重要举措，它关乎国计民生，影响和决定国家未来发展，与每个人的生活息息相关。

网络强国是一国综合实力的体现，也是一个国家基于现阶段发展的考量对未来战略发展加以预期和筹备。操作系统由于其在计算机系统、智能终端系统中发挥着最基本运行平台的特殊地位与作用，我国是否拥有自主操作系统技术与产业实力，对于我国提升网络空间竞争力，实现网络强国战略具有重要的基石作用。

操作系统的自主可控是网络强国的关键基石

操作系统之争是全球IT产业竞争的制高点

信息领域生态系统核心正在向操作系统迁移

国外操作系统垄断我国市场产生多层次利害关系

方兴东，张静等. 安全操作系统“中国梦”——中国自主操作系统战略对策研究报告[J]. 中国信息安全, 2014, (4): 72-97.

Importance of OS: from perspective of market values

公司	市值(单位: 亿美元)(截止 2014.4.10)	2013 年营收 (单位: 亿美元)	2013 年利润 (单位: 亿美元)	期末持有现金及等 价物总额 (单位: 亿美元)
苹果	4671.40	1709.10	370.37	1590
谷歌	3736.10	598.25	129.20	587.2
微软	3305.30	778.5	219	770
IBM	2037.70	997.51	164.83	
中国移动	1950.09	1014.44	195.9	686.90
三星	1914.89	2127	286	500
Oracle	1774.20	371.8	109	
亚马逊	1502.10	744.5	2.74	54.7
Facebook	1482.10	78.72	15	114.5
高通	1320.20	248.7	68.5	

在操作系统领域拥有竞争优势的三家企业（苹果、微软、谷歌）市值都在3000 亿美元以上，远超其他的互联网应用企业、软件企业、电信运营商、网络设备制造商、芯片厂商，这反映了资本市场对于拥有核心操作系统优势、能够构建生态系统的企业的看好程度远高于其他类型的科技企业。

百度	528.27	52.77	17.38	63.48
----	--------	-------	-------	-------

对于中国企业而言，如果要进入世界IT、互联网领域第一阵营，有必要在关键基础领域（如操作系统）拥有自己的核心技术优势，并以此为基础建立生态系统。这样才能保障企业在估值、营收等方面进入第一阵营。

这一讲要解决什么问题？



沈昌祥院士

若没有安全操作系统的支持，数据库就不可能具有存取控制的安全可信性，就不可能有网络系统的安全性，也不可能有应用软件信息处理的安全性。**因此，安全操作系统是整个信息系统安全的基础。**如果信息安全框架的构造只停留在网络防护的层面上，而忽略了操作系统内核安全这一基本要素，这如同将坚固的堡垒建立在沙丘之上，安全隐患极大。

**没有网络安全就没有国家安全
没有操作系统安全就没有网络安全**

当今的信息系统产生安全问题的基本原因是操作系统的结构和机制不安全，其根源在于：PC机硬件结构的简化，系统不分执行“态”，内存无越界保护等，使操作系统难以建立真正的TCB。这样就导致：资源配置可以被篡改；恶意程序被植入执行；利用缓冲区（栈）溢出攻击；非法接管系统管理员权限等安全事故。

操作系统安全是等级保护的关键技术

关于《信息安全等级保护管理办法》的通知

- 基础标准：《计算机信息系统安全等级保护划分准则》（GB17859）
- 基线标准：信息系统安全等级保护基本要求
- 辅助标准：定级指南、实施指南、测评要求
- 目标标准：

- 《信息系统通用安全技术要求》（GB/T20271）
- 《网络基础安全技术要求》（GB/T20270）
- 《操作系统安全技术要求》（GB/T20272）
- 《数据库管理系统安全技术要求》（GB/T20273）
- 《终端计算机系统安全等级技术要求》（GA/T671）
- 《信息系统安全管理要求》（GB/T20269）
- 《信息系统安全工程管理要求》（GB/T20282）

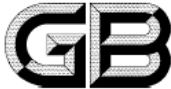
化技术委员会
护工作，经信

《信息安全技术操作系统安全技术要求（GB/T 20272-2006）》中对符合等级保护三级的操作系统（即操作系统安全标记保护级）中描述到，运行于网络环境的分布式操作系统，应统一实现强制访问控制功能，要由专门设置的系统安全员统一管理操作系统中与强制访问控制等安全机制有关的事件和信息，并将系统的常规管理、与安全有关的管理以及审计管理，分别由系统管理员、系统安全员和系统审计员来承担，按职能分割原则分别授予他们各自为完成自己所承担任务所需的权限，并形成相互制约关系。

支阿龙. 浅谈等级保护中的服务器操作系统安全[J]. 信息安全与通信保密,2009(1):62-63.

操作系统安全是等级保护的关键技术

ICS 35.040
L 80



中华人民共和国国家标准

GB/T 20272—2019
代替 GB/T 20272—2006

信息安全技术 操作系统安全技术要求

Information security technology—
Security technical requirements for operating system

2019-08-30 发布

2020-03-01 实施

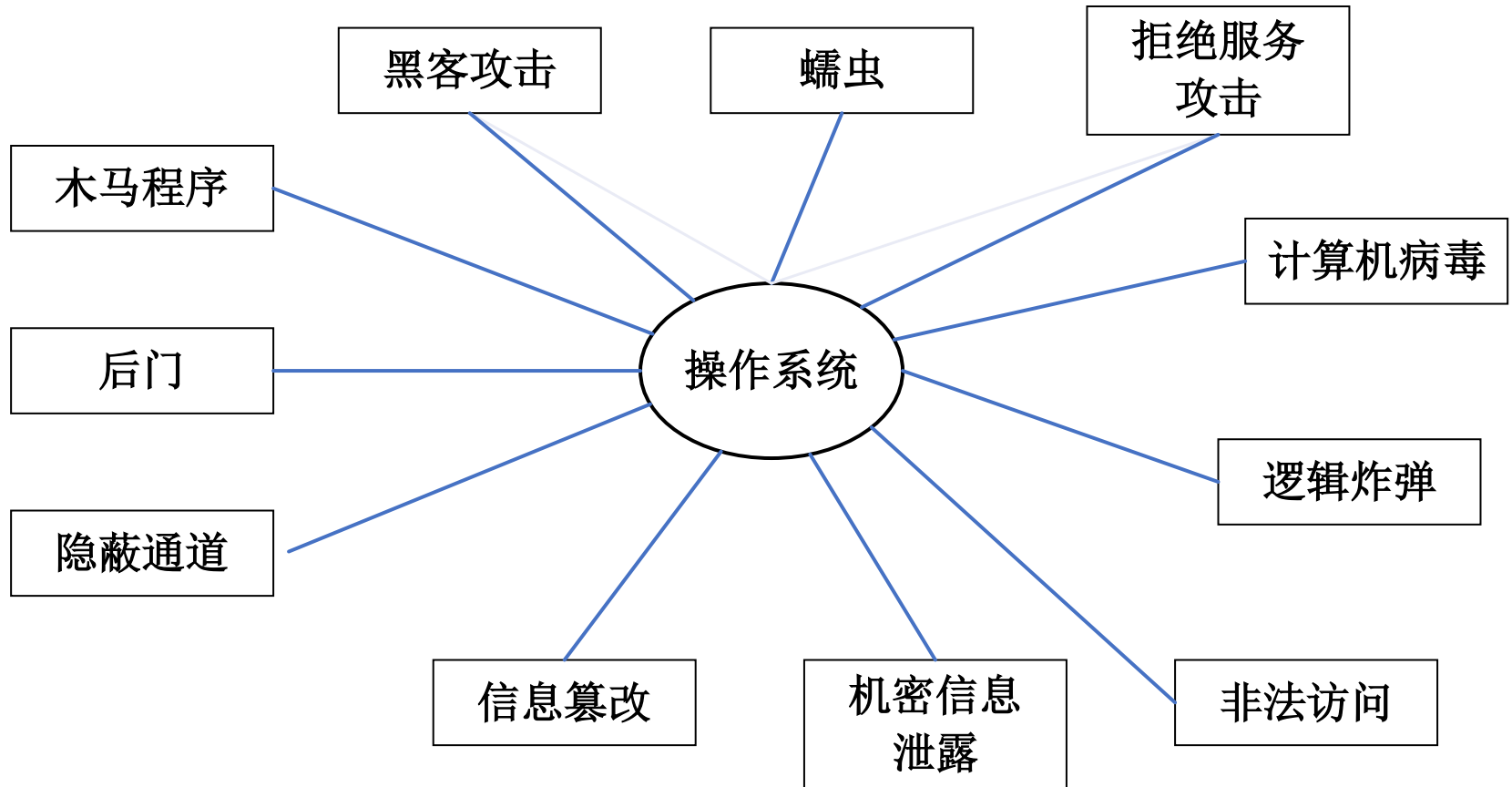
国家市场监督管理总局 发布
中国国家标准化管理委员会

6	安全技术要求	
6.1	第一级：用户自主保护级 ...	
6.1.1	安全功能要求	
6.1.2	自身安全要求	
6.1.3	安全保障要求	
6.2	第二级：系统审计保护级 ...	
6.2.1	安全功能要求	
6.2.2	自身安全要求	
6.2.3	安全保障要求	
6.3	第三级：安全标记保护级 ..	
6.3.1	安全功能要求	
6.3.2	自身安全要求	
6.3.3	安全保障要求	
6.4	第四级：结构化保护级	
6.4.1	安全功能要求	
6.4.2	自身安全要求	
6.4.3	安全保障要求	
6.5	第五级：访问验证保护级 ..	
6.5.1	安全功能要求	
6.5.2	自身安全要求	
6.5.3	安全保障要求	



操作系统安全问题的来源

操作系统面临的安全威胁



破解口令（password cracking），开天窗（trapdoor），走后门（backdoor），安放特洛伊木马（Trojan horse）。。。。。

关于漏洞的考量



Vulnerability Alerts



TheBestVPN.com

TheBestVPN.com is an independent reviewer of VPN services.



A Decade of Technical Vulnerabilities

EXAMINING THE VENDORS AND PRODUCTS
MOST VULNERABLE TO BAD ACTORS

<https://thebestvpn.com/vulnerability-alerts/>

To examine technical vulnerabilities of various vendors and products, TheBestVPN used recent data from the National Institute of Standards and Technology's National Vulnerability Database, which updates frequently. Their findings outline the type of vulnerabilities that users should be privy to and indicate the severity of attacks.

Top 20 Products With the Most Technical Vulnerabilities Over 20 Years

1999–2019

Debian Linux	3,067
Android	2,563
Linux kernel	2,357
Mac OS X	2,212
Ubuntu	2,007
Mozilla Firefox	1,873
Google Chrome	1,858
iPhone iOS	1,655
Windows Server 2008	1,421
Windows 7	1,283
Adobe Acrobat Reader DC	1,182
Adobe Acrobat DC	1,182
Windows 10	1,111
Adobe Flash Player	1,078
Windows Server 2012	1,050

2019

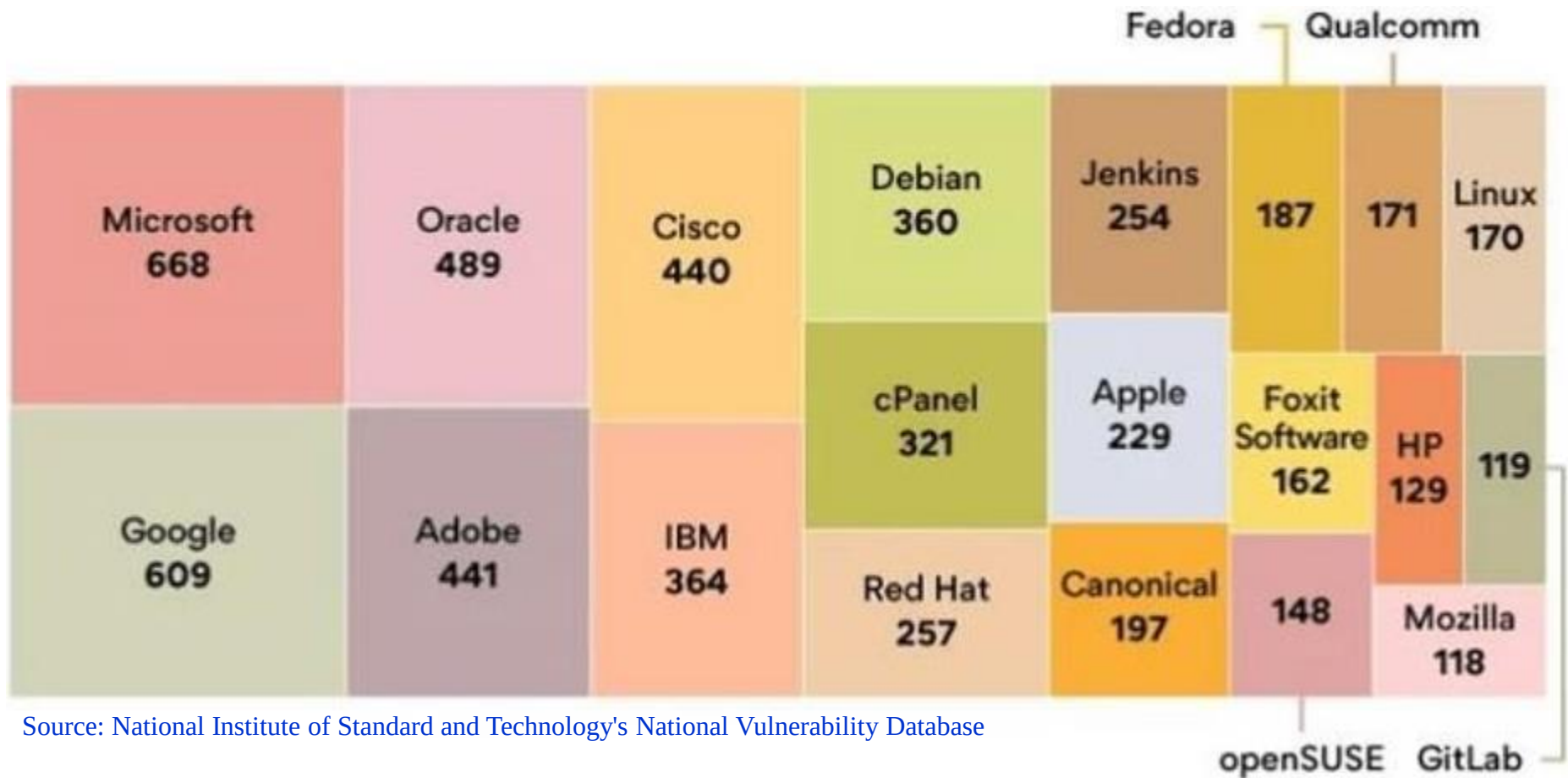
Android	414
Debian Linux	360
Windows Server 2016	357
Windows 10	357
Windows Server 2019	351
Adobe Acrobat Reader DC	342
Adobe Acrobat DC	342
cPanel	321
Windows 7	250
Windows Server 2008	248
Windows Server 2012	246
Windows 8.1	242
Windows RT 8.1	235
Ubuntu	190
Fedora	184

Debian Linux第一
Android第二

尽管许多人认为微软Windows是最易受攻击的操作系统，毕竟其对于新手的门槛较低。然而 TheBestVPN 根据美国国家标准技术研究院（NIST）国家漏洞数据库的数据分析表明：Debian Linux是过去20年中漏洞数量最多的操作系统。

Source: National Institute of Standard and Technology's National Vulnerability Database

Top 20 Vendors With the Most Vulnerabilities in 2019



Source: National Institute of Standard and Technology's National Vulnerability Database

Top 20 Vendors With the Most Vulnerabilities

From 2009 To 2019



Top 20 Vendors With the Most Vulnerabilities
From 1999 to 2019

Microsoft	6,814
Oracle	6,115
IBM	4,679
Google	4,572
Apple	4,512
Cisco	4,167
Adobe	3,314
Debian	3,197
Red Hat	2,805
Linux	2,370
Mozilla	2,199
Canonical	2,025
HP	1,794
Sun Microsystems	1,628
openSUSE	1,315
Apache	1,218
Fedora	757
GNU	738
Novell	665
PHP	626

Vulnerabilities
per Product

12.9
9.5
4.4
54.4
37.9
1.1
25.1
33.0
9.3
139.4
91.6
67.5
0.5
8.0
52.6
6.2
44.5
7.3
5.6
28.5

微软产品依然树大招风，仅2019年就曝出了668个漏洞。自2009年以来，微软已攒下6814个技术漏洞，使之成为20年来最容易被盯上的供应商。

Oracle、IBM、谷歌和苹果也进入了前五，分别有6115、4679、4572、4512个漏洞。

Products With the Most Vulnerabilities, by Year

	PRODUCT WITH THE MOST VULNERABILITIES	TOTAL NUMBER OF VULNERABILITIES
1999	Windows NT	64
2000	Linux	47
2001	Linux	47
2002	Internet Explorer	54
2003	Oracle Solaris	42
2004	Internet Explorer	59
2005	Linux kernel	133
2006	Mac OS X	106
2007	PHP	114
2008	Mac OS X	95
2009	Mozilla Firefox	126
2010	Google Chrome	150
2011	Google Chrome	266
2012	Google Chrome	249
2013	Linux kernel	189
2014	Internet Explorer	243
2015	Mac OS X	444
2016	Android	525
2017	Android	843
2018	Debian GNU/Linux	1,197
2019	Android	414

Android 在 2016 年、2017 年和 2019 年的漏洞数量最多，均为当年“榜首”。与之相比，苹果的 iOS 一次未上榜。这也从侧面印证了 iOS 相比 Android 更为安全。

谷歌 Chrome 浏览器连续三年（2010、2011 和 2012）成为漏洞最多的产品。而在编程语言中，PHP 在 2007 年以 114 个漏洞排名第一。

Note: Some products are defined in multiple times with different names in the database. For example, the top product in 2002 and 2004 was listed in the database as IE, a common abbreviation for Internet Explorer. Given that IE was listed as a product of Microsoft, we felt confident in labeling both instances as Internet Explorer for consistency and clarity.

关于攻击的考量
(以隐通道攻击为例)



隐通道（Covert channel）

- ❖ 1973年，B. W. Lampson通过对程序的限制问题（Confinement Problem）的研究提出了隐通道的概念。隐通道是一类不易被发现的数据泄密途径。

Butler W. Lampson, "A Note on the Confinement Problem", CACM on Operating Systems, Vol.16, No.10, October, 1973. pp 613-615

- ❖ **程序的限制问题**涉及程序的调用与信息传送

- 设程序B是由程序A调用运行的。
- 所谓对程序B的限制是指：制止程序B在运行期间向其他程序（程序A除外）传送信息。
- 程序B向它的owner传送有关程序A的信息属于信息泄漏。

隐通道（Covert channel）

Lampson关于隐通道的定义

按常规不会用于传送信息但却被利用于泄漏信息的信息传送渠道。

- ❖ 例如：一个程序通过对系统负载的影响的变化情况来向另一个程序暗示某种信息

TCSEC关于隐通道的定义

可以被进程用来以违反系统安全策略的方式进行非法传输信息的通信通道

- 存储隐通道
- 时间隐通道

隐通道

- ❖ 限制：进程P不能与进程Q通信。
- ❖ 共享：文件系统。
- ❖ 目的：进程P想发送一条消息给进程Q。
- ❖ 一种使用存储隐通道的方法：
 - 进程P在两进程都能读的一个目录中创建一个名为“send”的文件
 - 进程Q要读消息前，Q删除文件send
 - 进程P创建一个文件，命名为0bit或者1bit来代表要传输的比特；
 - 进程Q记录这个比特，并删除这个文件
 - ...
 - 最后进程P创建一个名为“end”的文件。
通信结束。

隐通道

- ❖ Marvin, S., et al., *Program confinement in KVM/370*, in *Proceedings of the 1977 annual conference*. 1977, ACM.
- ❖ 针对KVM/370系统的研究发现，可以基于两个虚拟机接收的CPU时间片来建立隐通道
 - 若发送方想要发送比特0，则立即释放CPU
 - 否则它将使用全部的时间片
 - 接收方通过获得CPU的速度可以推断出前者发送的是0还是1
- ❖ 共享资源：CPU时间

关于实际安全需求的考量



物联网中操作系统的安全性问题日趋突出

对物联网的具体利用进行分析，发现其核心——也就是操作系统安全问题表现得越来越突出，严重影响了物联网的利用效果，并对物联网的实际价值发挥造成了影响，所以解决操作安全成为了物联网应用中亟待解决的难题。

1

直接沿用原有的安全机制。例如，Android Things 直接沿用了Android系统的一些基础安全机制，并没有深入分析物联网设备实际的软硬件特性与需求

2

缺乏对终端系统安全设计。现有的物联网操作设计时普遍只关注其功能要求

3

没有充分利用设备自身硬件架构安全特性



虚拟化系统中操作系统的安全性问题

伴随着大数据和云时代的到来，虚拟化技术的应用已经越来越成熟。如何运用虚拟化技术给终端客户提供一个安全、稳定、高效的桌面环境，成为了一个日益热门的话题。

由著名波兰黑客 Joanna Rutkowska 发布的基于 Xen 和 Linux 的开源操作系统——Qubes 充分利用了虚拟化技术（基于安全虚拟机 Xen），所有用户应用程序都运行在 AppVM（基于 Linux 的轻量级虚拟机）中，彼此隔离。而联网代码使用 IOMMU/VT-d 放在一个非特权虚拟机中，在特权域（dom0）中没有任何联网代码。许多系统级组件放在沙盒中，以避免互相影响。

陆琦, 曹子玺, 薛质. 基于Xen的Qubes操作系统技术架构及安全性能分析[J]. 信息安全与技术, 2014, (1): 35-37.

嵌入式系统中操作系统的安全新问题

适航审定是大飞机研制中的关键环节，试飞测试是适航审定任务实施的重要基础；纵观国内外大飞机飞行试验均非常重视机载数据实时处理；在C919型号中对机载数据实时处理系统进行了研究，以VxWorks嵌入式实时操作系统为平台，通过对现有机载实时处理系统功能模块进行整合以及软件优化设计来提高C919机载数据实时处理系统性能。

嵌入式操作系统是嵌入式系统的核心，也是信息系统安全的重要保障，如果缺乏这个安全的根基，构建在操作系统上的应用系统以及整个嵌入式系统的安全性将得不到根本保障，因此提高嵌入式操作性系统的可靠性、安全性非常有必要。传统的嵌入式操作系统安全技术将操作系统所有安全相关功能集中在安全核心，但安全核心的开发使得操作系统内核变得更加庞大，导致无法对内核通过较高安全等级的安全评估和认证，也无法确保加密处理应用的真实安全性。



- 赵西香. 一种面向VxWorks操作系统的应用程序安全加载技术[J]. 电子世界, 2019, (14): 126-129.
林森, 游夏. 国产嵌入式安全操作系统技术[J]. 数字技术与应用, 2019, 37(4): 195-196.
吴海东, 聂睿. C919机载数据实时处理系统设计[J]. 计算机测量与控制, 2019, 27(4): 159-166.
高洪涛. 四级安全操作系统中审计系统的研究与设计[D]. 浙江大学, 2005.



操作系统的安全技术

What Does Operating System Security Mean?

Operating system security (OS security) is the process of ensuring OS integrity, confidentiality and availability.

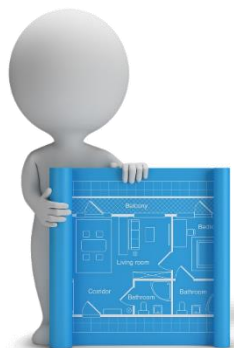
OS security refers to specified steps or measures used to protect the OS from threats, viruses, worms, malware or remote hacker intrusions. OS security encompasses all preventive-control techniques, which safeguard any computer assets capable of being stolen, edited or deleted if OS security is compromised.

OS security allows different applications and programs to perform required tasks and stop unauthorized interference.



<https://www.techopedia.com/definition/24774/operating-system-security-os-security>

操作系统的安全机制



设计一个安全的操作系统，从技术上讲有四种安全方法

1

隔离控制

2

访问控制

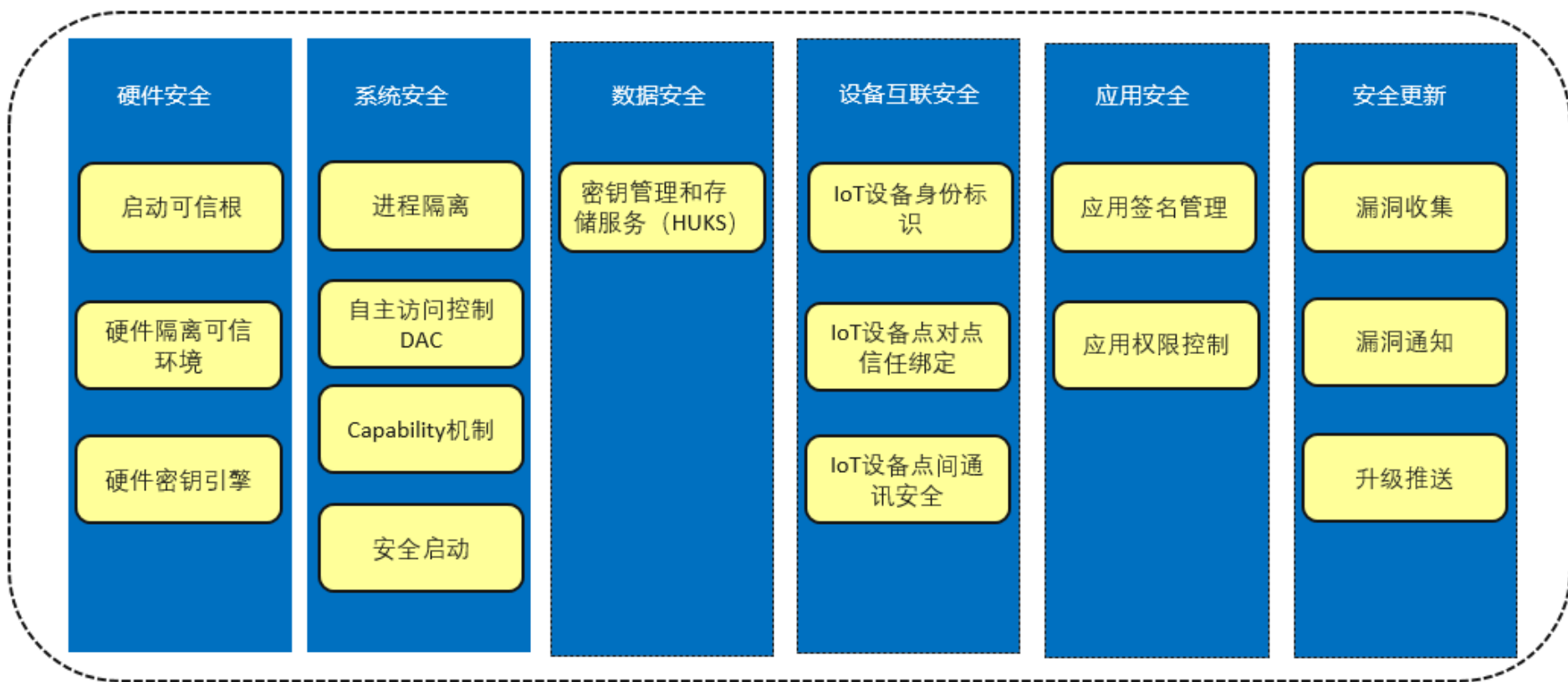
3

信息加密

4

审计跟踪

Harmony OS的安全保障示意图



Source: 《华为鸿蒙操作系统（OpenHarmony）v1.0 开发者文档》
<https://www.bookstack.cn/read/openharmony-1.0-zh-cn/security-%E5%AE%89%E5%85%A8%E6%8C%87%E5%8D%97-0.md>

操作系统的安全机制（重要）

隔离控制

物理
隔离

例如，把不同的打印机分配给不同安全级别的用户。

时间
隔离

例如，以不同安全级别的程序在不同的时间使用计算机。

加密
隔离

例如，把文件、数据加密，使无关人员无法阅读。

逻辑
隔离

例如，把各个进程的运行限制在一定的空间，使得相互之间不感到其他进程或程序的存在，如sandbox。

操作系统的逻辑隔离

逻辑隔离

首先要对存储单元的地址进行保护

使非法用户不能访问那些受到保护的存储单元

其次要对被保护的存储单元提供各种类型的保护

最基本的保护类型是“读 / 写”和“只读”。

复杂一些的保护类型还包括“只执行”、“不能存取”等操作。不能存取的存储单元，若被用户存取时，系统要及时发出警报或中断程序执行。

操作系统对内存的保护主要采用逻辑隔离方法

操作系统对存储器的保护

这页重要！！！！

操作系统对内存的保护主要采用了**逻辑隔离**方法

✱ 界限寄存器保护法

内存标志法

锁保护法

特征位保护法



- 在CPU中设置一对下限寄存器和上限寄存器，存放正在执行的程序在主存中的下限和上限地址。
- 可将一个寄存器作为基址寄存器，另一寄存器作为限长寄存器（指示存储区长度）
- 每当CPU要访问主存，硬件自动将被访问的主存地址与界限寄存器的内容进行比较，以判断是否越界。如果未越界，则按此地址访问主存，否则将产生程序中断——越界中断（存储保护中断）。

了解

操作系统对存储器的保护

操作系统对内存的保护主要采用了**逻辑隔离**方法

界地址寄存器
保护法

内存标志法

锁保护法

特征位保护法

“锁”是指为存储区设置的特定数字。

使用锁保护方式具有以下优点：

- 因为不同的存储区可以分配相同的锁，因此用户可以用同一钥匙打开不连续的若干区域。
- 只要锁和钥匙定义不同的对应方案，就可以使钥匙具有不同的优先级。

特征位即在每一个存储单元的前面设置一组特征位

特征位	数据指令代码
-----	--------

虚拟存储器的保护

了解

虚拟存储器一般都采用段 / 页技术进行管理

- 一般情况下，整个虚拟存储器被划分成若干个段，每个段再被划分成若干页。
- 如果在段、页描述中加入段、页保护信息，如对段或页可采取“只读”、“读 / 写”等保护措施，当计算机执行指令时，系统便根据保护类型检查这条指令的操作是否合法，如果不合法，就中断程序的执行。

操作系统的安全机制

访问控制

访问控制是操作系统的安全控制核心。访问控制是确定谁能访问系统，能访问系统何种资源以及在何种程度上使用这些资源。访问控制包括对系统各种资源的存取控制。

访问控制的三项基本任务

身份
认证

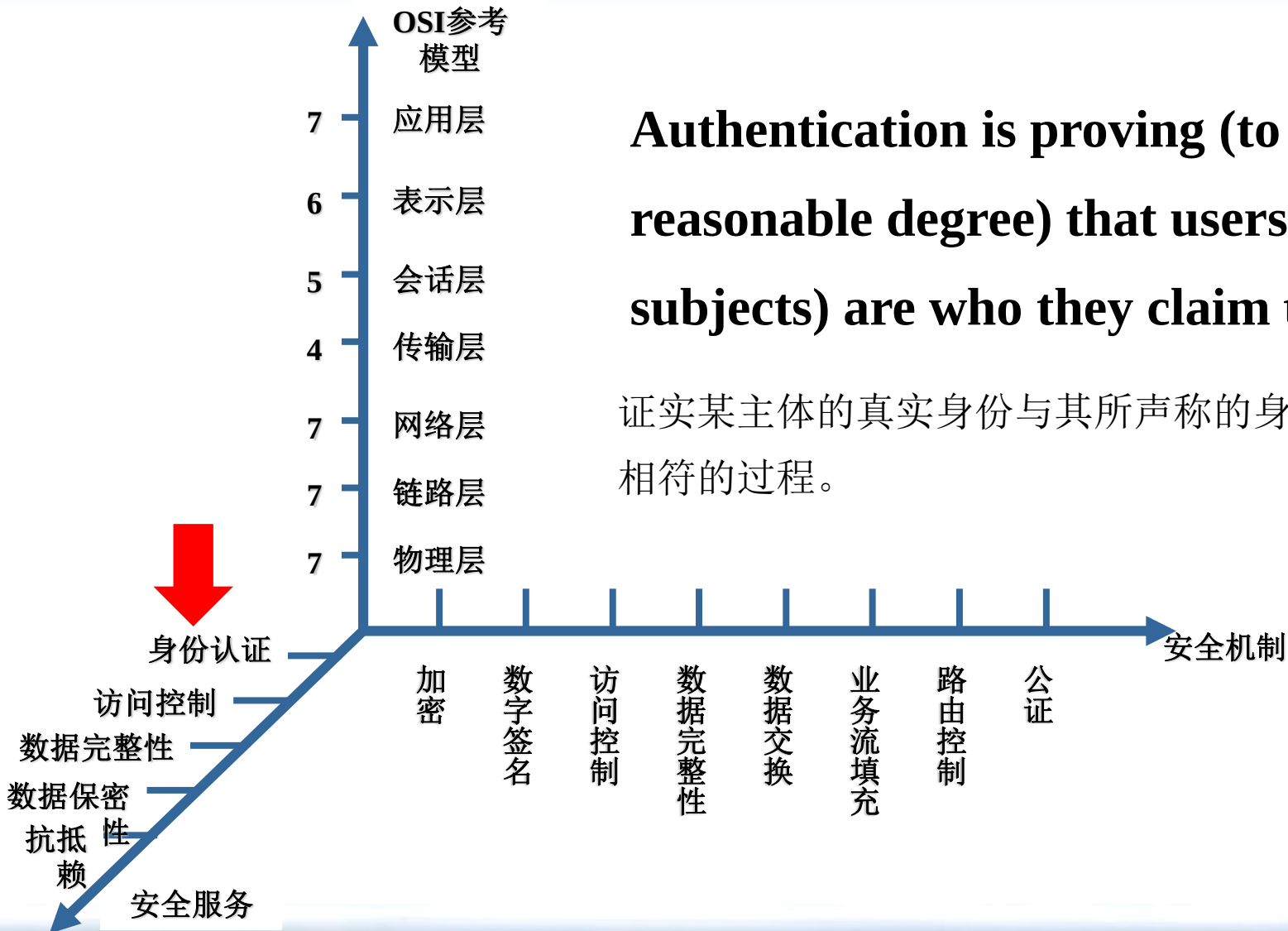
确定访问
权限

实施访问控
制的权限

身份认证

Authentication is proving (to some reasonable degree) that users (or subjects) are who they claim to be.

证实某主体的真实身份与其所声称的身份是否相符的过程。



身份认证的基本途径：身体就是身份证

□ 基于你所知道的（What you know）

知识、口令、密码

□ 基于你所拥有的（What you have）

身份证、信用卡、钥匙、智能卡、令牌等



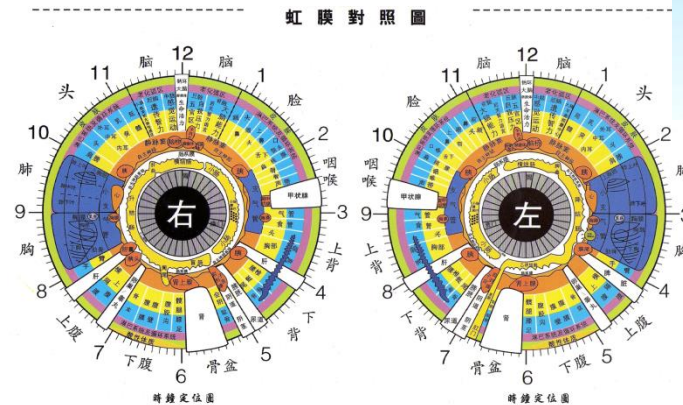
身份认证的基本途径：身体就是身份证

□ 基于你的个人特征（What you are）

指纹，笔迹，声音，手型，脸型，视网膜，虹膜



虹膜是环绕在瞳孔四周有色彩的环形薄膜部分，颜色完全由父母遗传基因决定，因人而异。



身份认证——一次性口令认证（OTP）

不是解决安全问题的终极方案

OTP的主要思路是：

在登录过程中加入不确定因素，使每次登录过程中传送的口令信息都不相同，以提高登录过程安全性。

例如：

登录密码=MD5(用户名+密码+时间)

系统接收到登录口令后做一个验算即可验证用户的合法性。





一次性口令是不是基本解决了安全问题？

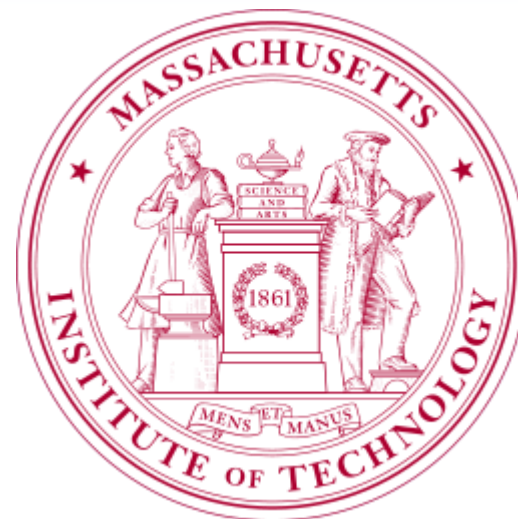
不是

请以银行的U盾为例
'随机种子'



身份认证——Kerberos认证

Kerberos was developed as the authentication engine for MIT's Project Athena in 1983. Released as Open Source in 1987, it became an IETF standard in 1993.

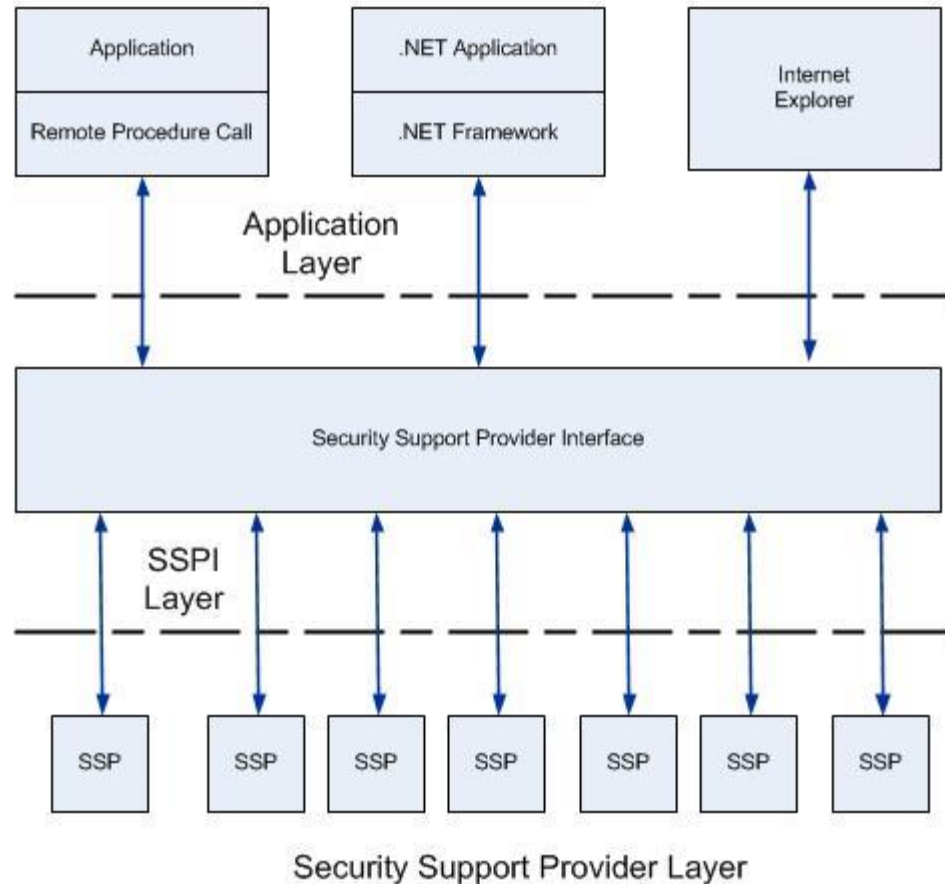


► *Our mission is to establish Kerberos as the universal authentication platform for the world's computer networks.*

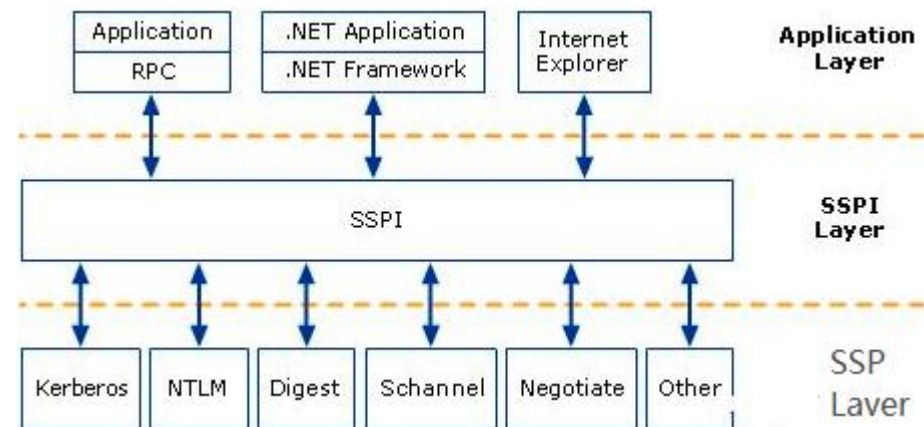
Massachusetts Institute of Technology

Security Support Provider

Security Support Provider Interface Architecture



SSP (Security Support Provider), 又名 Security Package, 实际就是一个 DLL, 用来实现身份认证, 例如: NTLM、Kerberos、Negotiate、Secure Channel (S-channel)、Digest、Credential (CredSSP) 等。



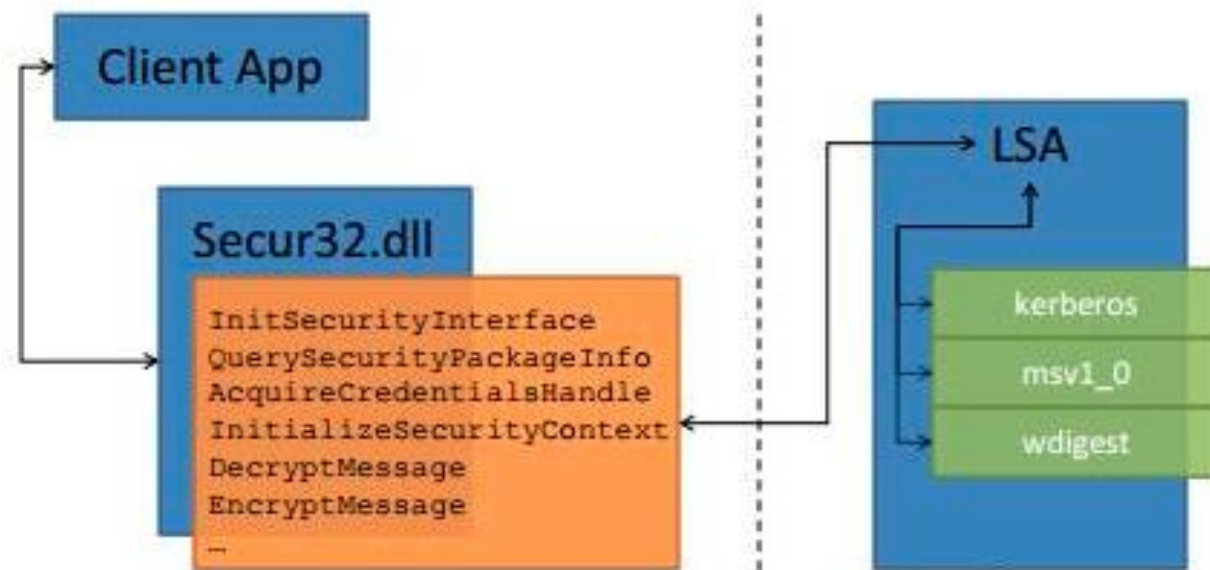
Windows、Linux、Mac这3大主流操作系统均支持Kerberos协议

[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn751052\(v=ws.11\)?redirectedfrom=MSDNDocs](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn751052(v=ws.11)?redirectedfrom=MSDNDocs)

Windows 2022/2019/2016 Server的身份认证

操作系统	特征	说明
Active Directory 域中的身份验证	Kerberos	Microsoft Windows Server 操作系统可实现 Kerberos 版本 5 身份验证协议和对公用密钥身份验证的扩展。Kerberos 身份验证客户端可作为安全支持提供程序 (SSP) 实现，并可以通过安全支持提供程序接口 (SSPI) 进行访问。初始用户身份验证与 Winlogon 单个登录体系结构相集成。Kerberos 密钥发行中心 (KDC) 与在域控制器上运行的其他 Windows Server 安全服务相集成。KDC 使用域的 Active Directory 目录服务数据库作为安全帐户数据库。Active Directory 是默认 Kerberos 实现所必需的。 有关更多资源，请参阅 Kerberos 身份验证概述。
Web 上的安全身份验证	Schannel 安全支持提供程序中实现的 TLS/SSL	传输层安全 (TLS) 协议版本 1.0、1.1 和 1.2、安全套接字层 (SSL) 协议版本 2.0 和 3.0、数据报传输层安全协议版本 1.0 和专用通信传输 (PCT) 协议版本 1.0 基于公钥加密。安全通道 (Schannel) 提供程序身份验证协议套件提供这些协议。所有 Schannel 协议使用客户端和服务端模型。 有关其他资源，请参阅 TLS - SSL (Schannel SSP) 概述。
对 Web 服务或应用程序进行身份验证	Windows 集成身份验证摘要式身份验证	有关其他资源，请参阅集成 Windows 身份验证和摘要式身份验证，以及高级摘要式身份验证。
对旧版应用程序进行身份验证	NTLM	NTLM 是一种质询-响应式身份验证协议。除了身份验证之外，NTLM 协议还选择性地提供会话安全性，特别是通过 NTLM 中的签名和密封功能实现消息完整性和保密性。 有关更多资源，请参阅 NTLM 概述。
利用多重身份验证	智能卡支持生物识别支持	智能卡是为任务（如客户端身份验证、登录到域、代码签名和保护电子邮件）提供安全解决方案的防篡改且便携式的方式。 生物识别依赖于测量个人的不变物理特征以便对此人进行唯一标识。指纹是最常用的生物识别特征，数以百万计的指纹生物识别设备都嵌入到个人计算机和外围设备中。 有关其他资源，请参阅 智能卡技术参考。
提供本地管理、存储和重新使用凭据	凭据管理本地安全机构密码	凭据管理Windows确保安全地存储凭据。通过应用程序或网站在安全桌面上收集凭据（适用于本地或域访问），以便每次访问资源时都能出现正确的凭据。
扩展对旧版系统的现代身份验证保护	身份验证的扩展保护	该功能可通过使用集成的 Windows 身份验证 (IWA) 增强对网络连接进行身份验证时的凭据保护和处理。

身份认证——Kerberos认证



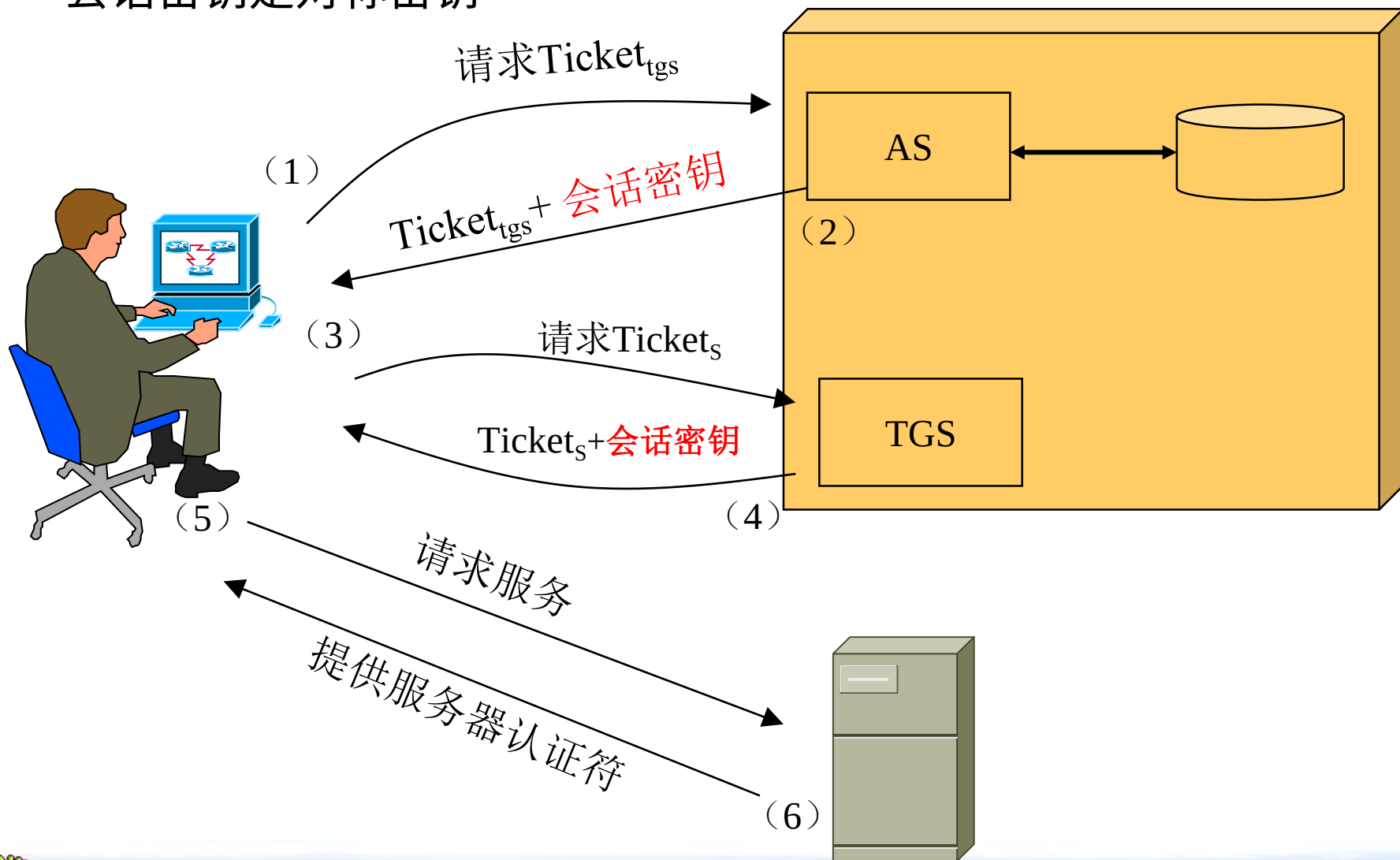
LSA (Local Security Authority) 用于身份认证，常见进程为lsass.exe；但LSA是可扩展的，在系统启动的时候SSP会被加载到进程lsass.exe中。这相当于我们可以自定义一个dll，在系统启动的时候被加载到进程lsass.exe

Client APP是我们自定义的DLL，通过Secur32.dll可以调用“credential capture API”来获取LSA的信息。



Kerberos v4 的认证过程

会话密钥是对称密钥



两个票据，三台服务器，四个参与者，五个会话密钥



Kerberos报文交换第一轮： 获取票据许可票据

Step (1) 用户请求票据许可票据

- 用户请求票据许可票据的工作在登录工作站时进行。
- 登录时用户被要求输入用户名，输入后系统会向认证服务器AS以明文方式发送一条包含用户和TGS服务两者名字的请求。

$C \rightarrow AS : ID_C \parallel ID_{tgs} \parallel TS_1$

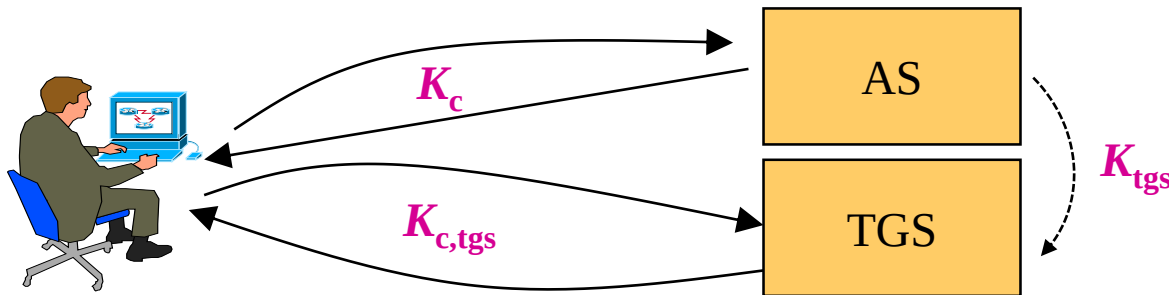
Kerberos报文交换第一轮：获取票据许可票据

Step (2) AS发放票据许可票据和会话密钥

认证服务器检查用户如果有效，随机产生一个用户和TGS之间的会话密钥 $K_{c,tgs}$ ，然后创建一个票据许可票据 $Ticket_{tgs}$ （票据许可票据使用 K_{tgs} 加密）。认证服务器向用户发送票据许可票据和会话密钥 $K_{c,tgs}$ ，发送的消息用只有用户和AS知道的 K_c 来加密（ K_c 的值基于用户的密码）。

AS $\rightarrow$ C : $E_{K_c}[K_{c,tgs} \parallel ID_{tgs} \parallel TS_2 \parallel Lifetime_2 \parallel Ticket_{tgs}]$

$Ticket_{tgs} = E_{K_{tgs}}[K_{c,tgs} \parallel ID_C \parallel AD_C \parallel ID_{tgs} \parallel TS_2 \parallel Lifetime_2]$



Kerberos报文交换第二轮： 获取访问票据

Step (3) C请求服务器票据

用户工作站收到AS回应后，要求用户输入密码，将密码转化为DES密钥 K_c ，然后将AS发回的信息解开，将Ticket_{tgs}和 $K_{c,tgs}$ 保存用于以后的通信，为了安全性用户密码和密钥 K_c 被删掉。

一个票据只能申请一个特定的服务，所以用户必须为每一个服务器申请新的票据，用户可以从TGS处得到票据Ticket_s。

用户首先向TGS发出申请服务器票据的请求。请求信息中包含TGS服务器的名字，上一步中得到的请求TGS服务的加密票据Ticket_{tgs}，还有用会话密钥 $K_{c,tgs}$ 加密过的Authenticator信息。

$C \rightarrow TGS: ID_{tgs} \parallel Ticket_{tgs} \parallel Authenticator_c$

身份认证: {
 $Authenticator_c = E_{K_{c,tgs}}[ID_c \parallel AD_c \parallel TS_3]$
 $Ticket_{tgs} = E_{K_{tgs}}[K_{c,tgs} \parallel \underbrace{ID_c \parallel AD_c}_{一致} \parallel ID_{tgs} \parallel TS_2 \parallel Lifetime_2]$

$AS \rightarrow C: E_{K_c}[K_{c,tgs} \parallel ID_{tgs} \parallel TS_2 \parallel Lifetime_2 \parallel Ticket_{tgs}]$

Kerberos报文交换第二轮： 获取访问票据

Step (4) TGS发放服务器票据和会话密钥

TGS收到请求后，用密钥 K_{tgs} 和会话密钥 $K_{c,tgs}$ 分别解开 $Ticket_{tgs}$ 和 $Authenticator_c$ ，根据两者的信息鉴定用户身份是否有效。如果有效，TGS生成用于C和S之间通信的会话密钥 $K_{c,s}$ ，并生成C申请S服务的票据 $Ticket_s$ ，其中包含C和S的名字、C的网络地址、当前时间、有效时间和刚才产生的会话密钥 $K_{c,s}$ 。

TGS最后将加密后的票据 $Tickets$ 和会话密钥 $K_{c,s}$ 用用户和TGS之间的会话密钥 $K_{c,tgs}$ 加密后发送给用户。用户C得到回答后，用 $K_{c,tgs}$ 解密，得到所请求的票据和会话密钥。

$$TGS \rightarrow C : E_{K_{c,tgs}}[K_{C,S} \parallel ID_S \parallel TS_4 \parallel Ticket_s]$$

$$Ticket_s = E_{K_s}[K_{C,S} \parallel ID_C \parallel AD_C \parallel ID_S \parallel TS_4 \parallel Lifetime_4]$$

K_s 是TGS服务器和Server之间的共享密钥

$$C \rightarrow TGS: ID_{tgs} \parallel Ticket_{tgs} \parallel Authenticator_c$$

$$Ticket_{tgs} = E_{K_{tgs}}[K_{c,tgs} \parallel ID_C \parallel AD_C \parallel ID_{tgs} \parallel TS_2 \parallel Lifetime_2]$$

$$Authenticator_c = E_{K_{c,tgs}}[ID_c \parallel AD_c \parallel TS_3]$$

Kerberos报文交换第三轮：获取服务

Step (5) 工作站将票据和认证符发给服务器

$C \rightarrow S: \text{Ticket}_S \parallel \text{Authenticator}_c$

$\text{Ticket}_S = E_{K_S} [K_{c,s} \parallel \text{ID}_c \parallel \text{AD}_c \parallel \text{ID}_s \parallel \text{TS}_4 \parallel \text{Lifetime}_4]$

$\text{Authenticator}_c = E_{K_{c,s}} [\text{ID}_c \parallel \text{AD}_c \parallel \text{TS}_5]$

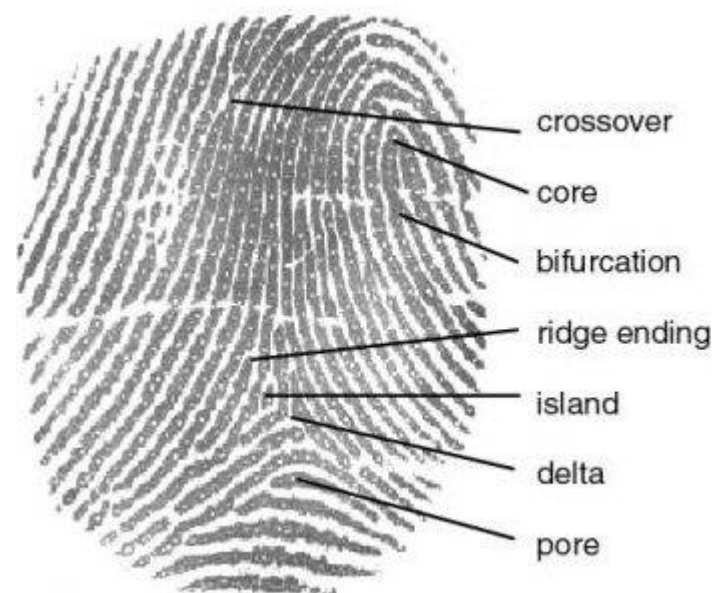
Step (6) 服务器验证票据 Ticket_S 和认证符中的匹配，然后许可访问服务。如果需要双向认证，服务器返回一个认证符

$S \rightarrow C : E_{K_{c,s}} [\text{TS}_5 + 1]$

掌型与指纹识别



指纹套



如果没有任何保护措施，基于指纹的身份认证系统同样对重发攻击没有免疫力，攻击者能够简单地绕过指纹采样设备，直接将一个比特串发往认证服务器，从而假冒合法用户的身份访问网络资源。因此，象密钥一样，指纹认证中的指纹数据必须得到保护

生物特征介绍（续）

Thermographic scan



<http://www.biofs.com/eng/s1.php>

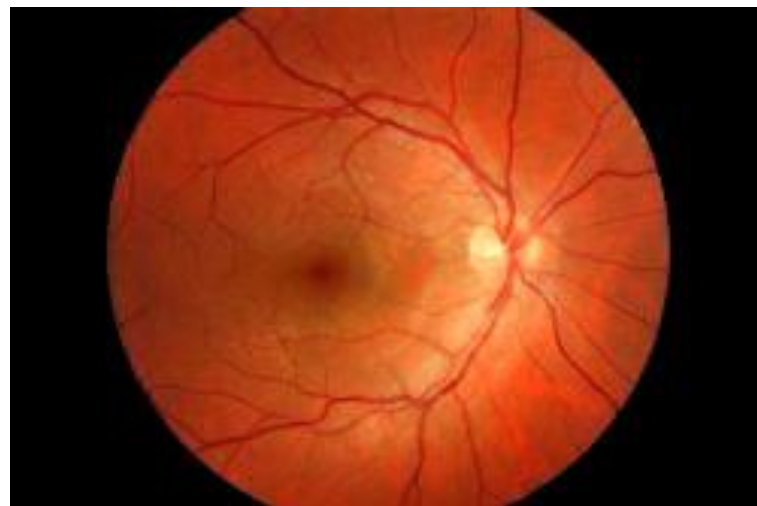


<http://www.cs.bham.ac.uk/~mdr/teaching/modules03/security/students/SS3/handout/index.html>

视网膜纹路识别



http://www.arcent.army.mil/cflcc_today/2005/january/iraqi_election.asp



http://www.eyes.co.nz/eye_care.html

思考题

对于物联网这样一个完全分布式架构的网络，其身份认证面临哪些困难和挑战？

在物联网环境中部署身份验证和访问控制机制时，有许多因素会使任务复杂化。这是因为大多数设备的处理能力、存储空间、带宽和能量都是有限的。由于常见身份验证协议的通信开销，大多数传统身份验证和授权技术过于复杂，无法在资源受限的物联网设备上运行。另一个问题是，设备有时部署在可能无法或无法提供物理安全的区域。

还有非常广泛的硬件和软件堆栈需要考虑。这导致大量设备通过多种标准和协议进行通信——这与更传统的计算环境不同。例如，研究人员确定了物联网环境中至少84种不同的身份验证机制，这些机制要么是在2019年提出的，要么是在2019年投入生产的。由于缺乏标准和物联网特定的访问控制模型，保护设备和网络安全任务变得更加复杂。

请阅读课后参考文献《物联网（IoT）中的身份认证》



改进物联网访问控制的方法

任何试图管理数千个分布广泛的物联网设备的集中访问管理模型都有其局限性，没有一种方法适用于所有场景。寻求开发去中心化物联网访问控制服务的供应商正在研究**区块链技术**如何消除集中式系统造成的问题。网络管理员和安全团队必须紧跟最新发展，因为它们可能在不久的将来带来真正可扩展的服务产品。

在此之前，每一个物联网设备必须有一个唯一的身份，当设备试图连接到网关或中央网络时，可以对其进行身份验证。有些设备仅根据其IP或MAC（媒体访问控制）地址进行标识，而其他设备则可能安装了证书。但是识别任何类型设备的更好方法是通过**机器学习**。除了行为分析（如API、服务和数据库请求）之外，还可以使用静态特性来完成此任务，以更好地确保设备的身份。身份和身份验证行为的结合还提供了根据上下文不断调整访问控制决策的能力——即使对于资源有限的设备也是如此。

这种基于属性的访问控制模型根据对设备、资源、操作和上下文进行分类的一系列属性来评估访问请求。它还提供更多动态访问控制功能。可以基于上下文属性中的更改实时更新对操作和请求的批准。但是，它确实需要管理员选择和定义一组属性和变量，以构建一套全面的访问控制规则和策略。

操作系统的安全模型



访问监控模型

单级模型，最简单的安全模型，是体现有限型访问控制的模型。它对每一个主体-客体对，只作“可”还是“否”的访问判定。这种模型论证比较脆弱，它所表达的安全需求没有特别详尽的说明。



“格”模型

多级模型。把用户（主体）和信息（客体）进一步按密级和类别划分。访问控制根据“工作需要，给予最低权限”的原则，只有当主体的密级等于或高于客体，主体的类别等于或包含客体时，主体才能访问客体。



Bell-La Padula模型

多级模型，用于防止信息泄漏，而不是防止主体对客体的非授权修改。它们只处理了信息的保密问题，而没有解决信息的完整性问题。



BIBA模型

多级模型，保证信息流完整性的控制模型，它把主体和客体按类似密级那样的完整级进行分类。完整级是一个由低到高的序列，其访问遵循“简单完整性”和“完整性星”两条原则。

操作系统的安全设计

安全操作系统的设计原则

- **最小权限原则**。赋予主体完成工作所必需的最小权限，减少不必要的损害。
- **完整性原则**。对所有保护对象的每次访问都必须接受检查。
- **经济性原则**。采用最简单、最直接的手段，对系统进行全面、充分的检查和验证：另外，安全措施代价应该小于被保护对象的价值。
- **公开性原则**。系统的安全性不能建立在对系统某些技术保密的基础上，而应让这些技术经受充分的检验。
- **权限分离原则**。理想的访问权应取决于两个以上条件的同时满足。
- **最小共同性原则**。用物理或逻辑上的隔离来减少共享可能造成的危害。
- **易用性原则**。系统人机接口的安全措施必须简单易用。
- **默认安全原则**。未经说明或权限不明的访问作为不允许访问处理。

所谓“安全操作系统设计”，就是指安全性必须在操作系统的各个部分予以考虑，安全性必须在操作系统开发的初期就予以考虑。

操作系统的加密机制

加密机制用于安全传输

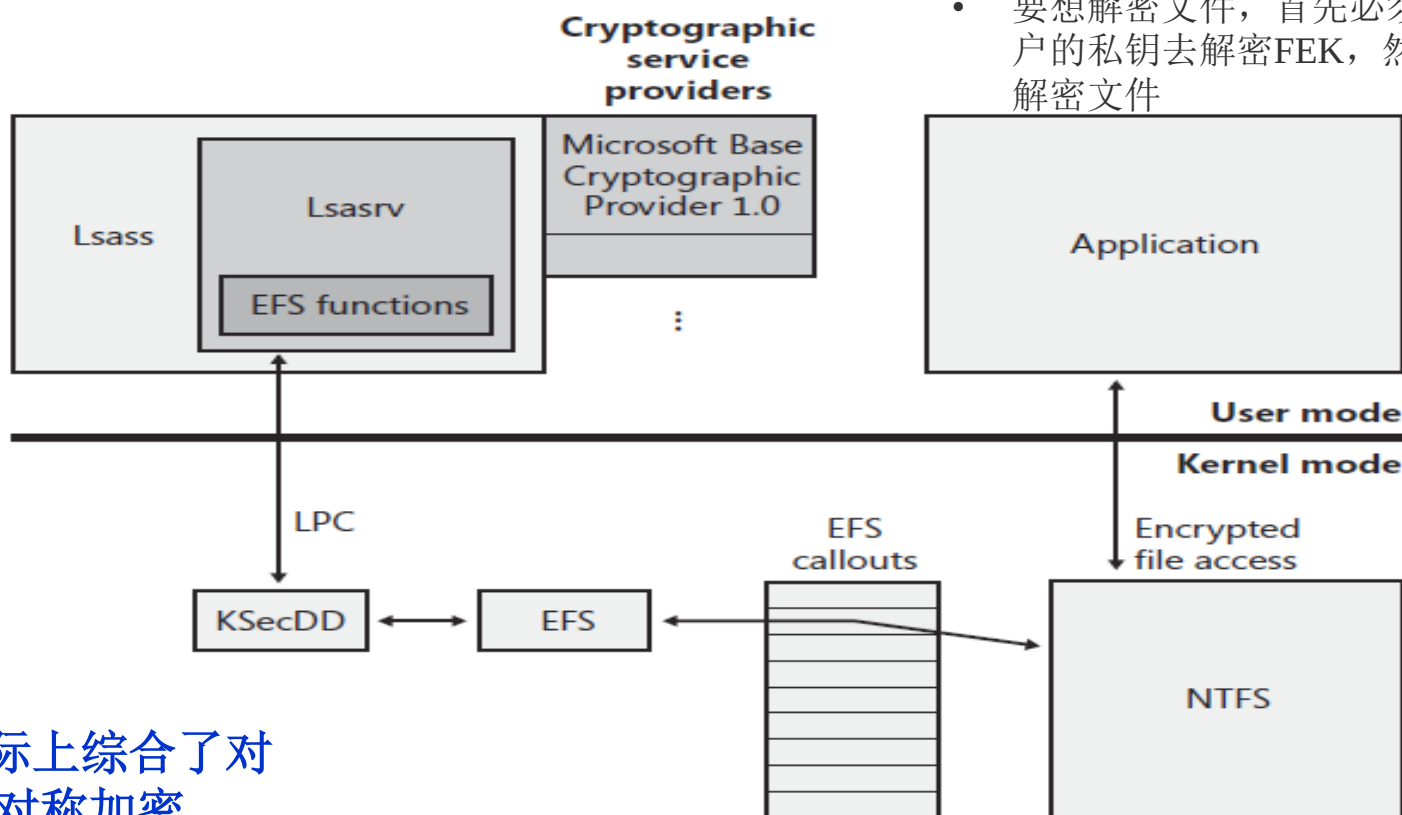
Internet协议安全性（IPSec）是一种开放标准的框架结构，通过使用加密的安全服务以确保在IP网络上进行保密而安全的通信。作为网络操作系统的 Windows 2003 Server，在分析它的安全机制时，也应该考虑到IP安全策略机制。

一个IPSec安全策略由IP筛选器和筛选器操作两部分构成。其中IP筛选器决定哪些报文应当引起IPSec安全策略的关注，筛选器操作是指“允许”还是“拒绝”报文的通过。在Windows 2003 Server系统的服务端和客户端都提供了对IPSec的支持，从而增强了安全性。

操作系统的加密机制

加密机制用于文件安全

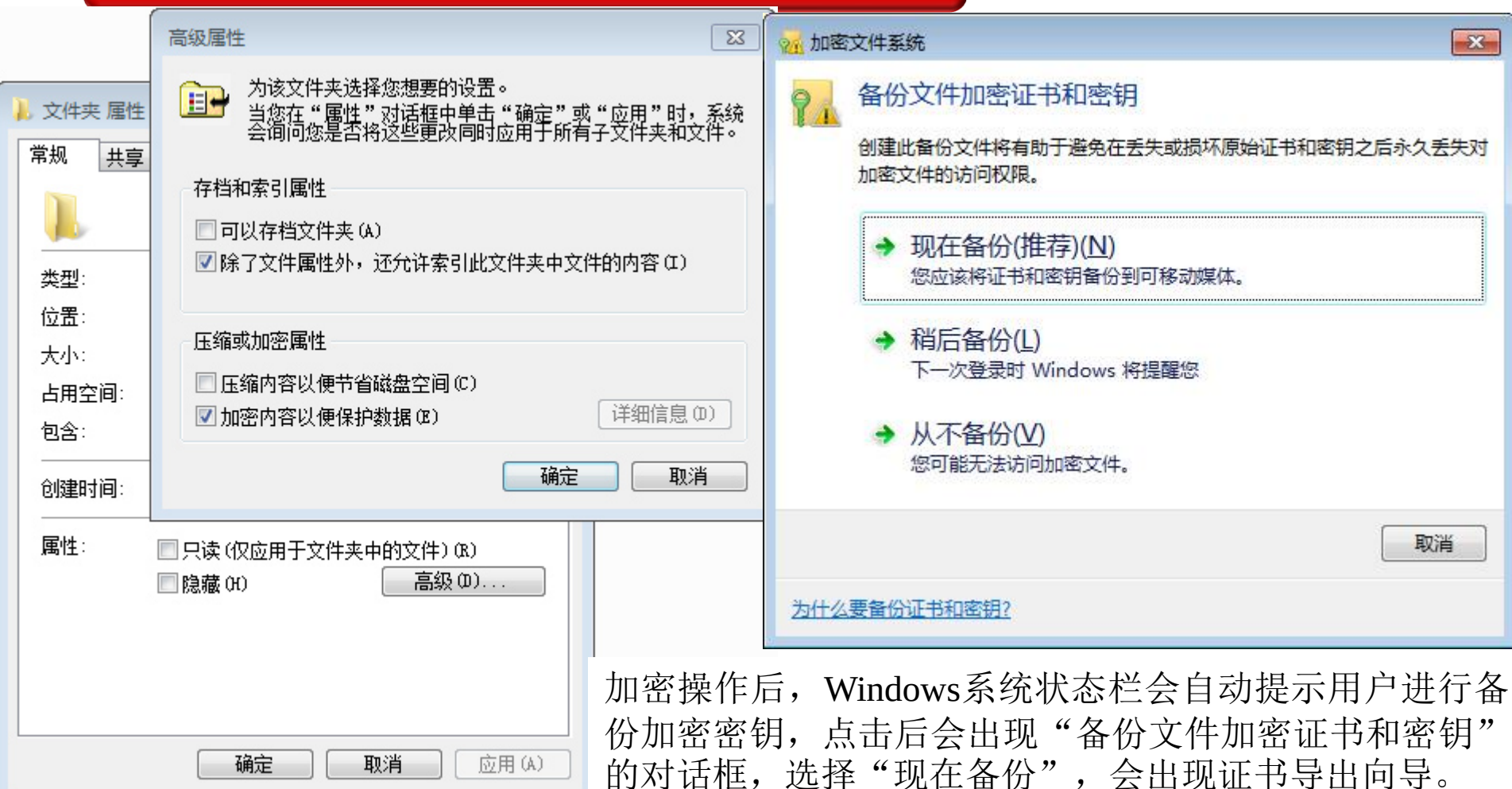
- 随机生成一个文件加密密钥（FEK）用来加密和解密文件
- FEK会被当前帐户的公钥进行加密，加密后的FEK副本保存在文件\$EFS属性的DDF字段
- 要想解密文件，首先必须用当前用户的私钥去解密FEK，然后用FEK去解密文件



EFS加密实际上综合了对称加密和不对称加密

操作系统的加密机制

加密机制用于文件安全



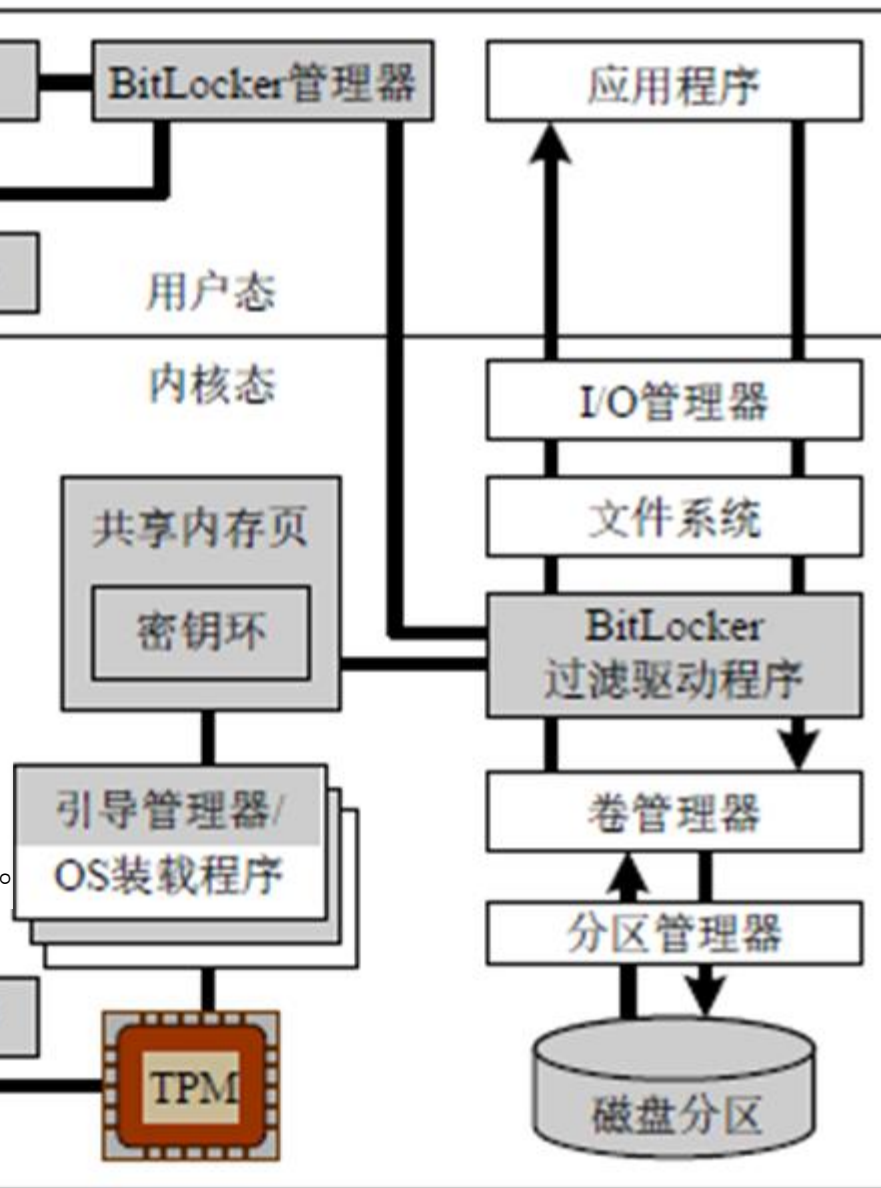
加密操作后，Windows系统状态栏会自动提示用户进行备份加密密钥，点击后会出现“备份文件加密证书和密钥”的对话框，选择“现在备份”，会出现证书导出向导。

Microsoft的BitLocker加密磁盘

Windows 7企业版及以上版本或旗舰版

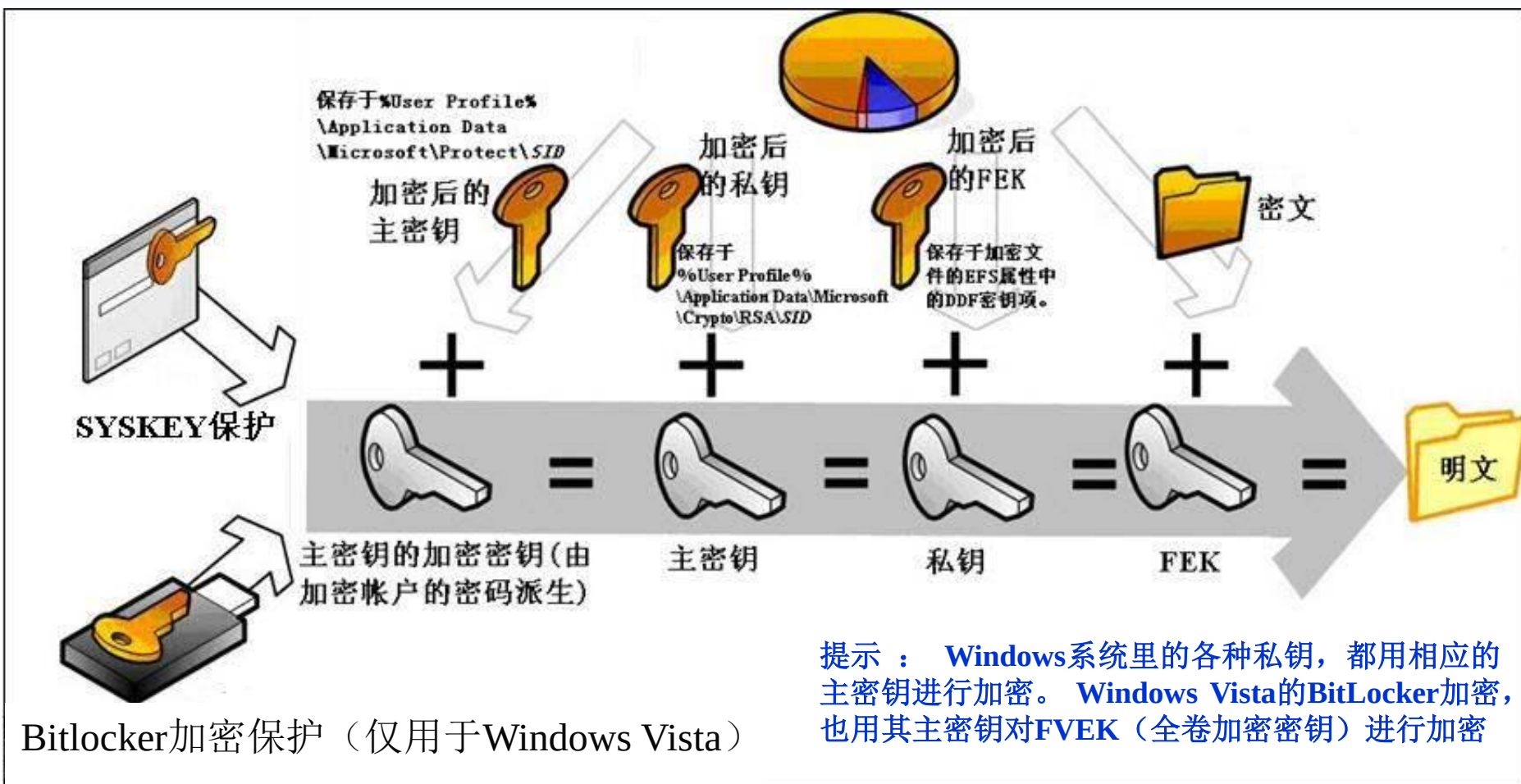
保护整个磁盘不被脱机攻击，也不会被Windows外的其他任何系统所访问

密钥以加密形式保存在TPM芯片中，这样一来要启动Windows或读取系统里的文件就必须提供TPM里的密钥。



普通笔记本中的指纹识别技术一般是把指纹验证信息储存在硬盘中，而ThinkPad中的TPM安全芯片则是直接将指纹识别信息置于安全芯片中。一旦遭到暴力破解，安全芯片就启动自毁功能，这样保证了个人信息资料不会泄密。TPM安全芯片和笔记本上的指纹识别模块搭配能达到最高的安全级别，即便是在无尘实验室对磁盘进行暴力拆解，也无法获得有效信息。

EFS和Bitlocker的结合



Windows系统还会对EFS添加两层保护措施:

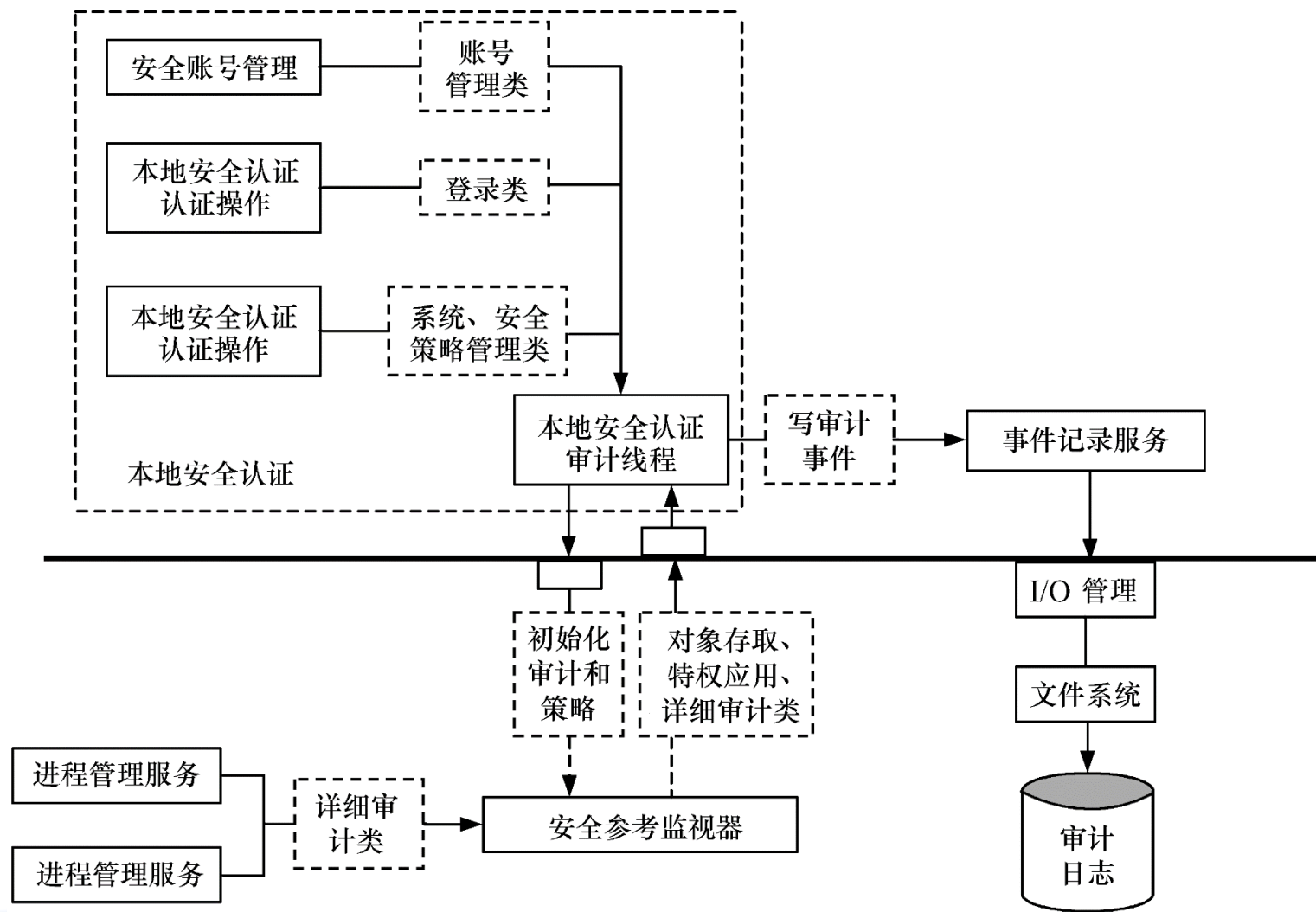
- (1) Windows会用64字节的主密钥 (Master Key) 对私钥进行加密，加密后的私钥保存在以下文件夹：
%UserProfile%\Application Data\Microsoft\Crypto\RSA\SID
- (2) 为了保护主密钥，系统会对主密钥本身进行加密 (使用的密钥由帐户密码派生而来)，加密后的主密钥保存在以下文件夹：
%UserProfile%\Application Data\Microsoft\Protect\SID

操作系统的安全审计

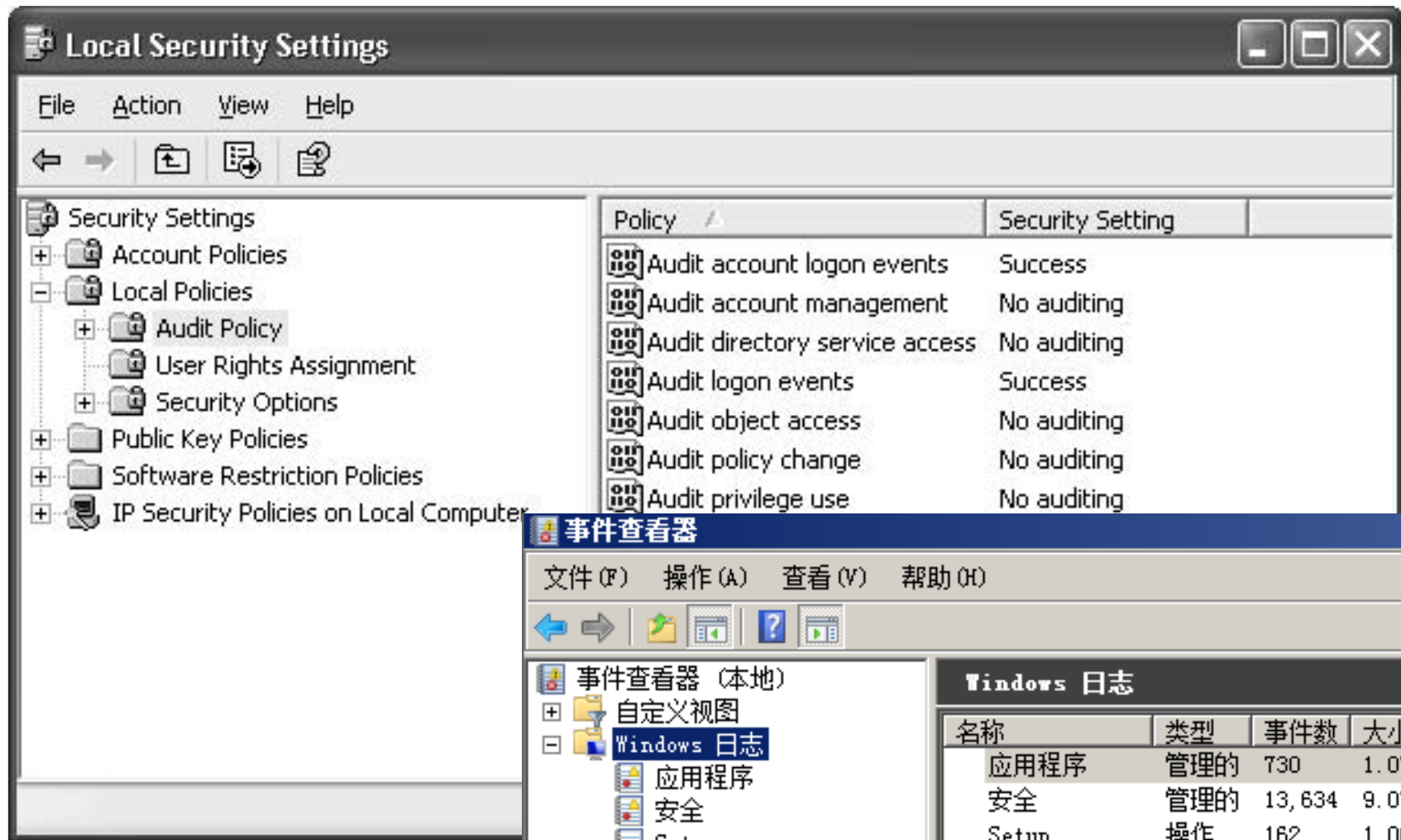
要求任何影响系统安全性的行为都被跟踪和记录在案，安全系统拥有把用户标识与它被跟踪和记录的行为联系起来的能力。

- 审计信息必须有选择性的保留和保护，所有与安全相关的事件记录在审计日志文件中，所有审计数据必须防止受到未授权的访问、修改和破坏，以作为日后对事件调查的依据。
- 审计系统能记录以下事件：和标识与鉴别机制相关的事件、将客体导入用户地址空间的操作、删除客体、系统管理员执行的操作及其他与安全相关的事件。

审计子系统结构图



操作系统的安全审计



Security Policy Editor aud

Harmony OS的安全机制

2021年10月22日，在华为开发者大会上，华为常务董事、消费者业务CEO、智能汽车解决方案CEO余承东宣布，鸿蒙系统不断迭代演进，HarmonyOS3开发者预览版正式发布。他表示，截至目前，搭载HarmonyOS的设备数量超1.5亿，成为史上发展最快的终端操作系统，用户数有望在年底超2亿。

如今，已有510万开发者加盟华为生态，全球超7.3亿用户正在使用华为应用市场。为了进一步吸引开发者，华为提出了星耀计划等多个部署。



Harmony OS的可信机制



TPM

(OS volume only)



TPM And Startup Key

(OS volume only)

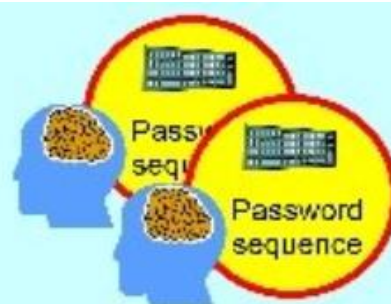


TPM And PIN

(OS volume only)



External Key



Numerical Password

《华为鸿蒙操作系统(OpenHarmony) v1.0 开发者文档》

硬件隔离可信环境

硬件隔离的可信环境，遵循了可信计算系统的设计理念。可信环境内外形成了两个世界：可信世界与不可信世界，两者之间存在清晰而明确的隔离边界；OpenHarmony设备在可信环境中实现了核心敏感数据的保护机制，可确保即使不可信世界的操作系统存在漏洞且被利用，也依然能确保可信环境中敏感数据的安全。

OpenHarmony设备的可信环境，基于硬件的安全隔离机制构建，在不同的OpenHarmony设备上芯片隔离机制略有差异，较为通用的方法是采用ARM的TrustZone技术。在部分Risc-V芯片平台上，也可能采用独立安全核的形式来构建可信环境。

可信环境中，运行特定的、精简的操作系统iTrustee lite，用于管理可信环境的资源和任务调度，给OpenHarmony设备提供安全服务。密钥管理及数据安全，是可信环境中最为常见的安全服务，设备在eFuse/OTP中存有硬件唯一根密钥，可信环境可基于该密钥结合业务上下文衍生出多种密钥，给应用提供密钥管理和数据加解密相关的服务；设备核心密钥生命周期不离开可信环境。可信环境同样可提供身份认证、系统状态监控、数据安全存储等安全服务，提高设备安全性。

Capability机制

Capability机制实际上是对root权限的具体细分。在多用户计算机系统中，一般会有一个特殊的角色拥有系统的所有权限，这个角色一般是系统管理员（root）。对于OpenHarmony这种需要支持三方应用生态的内核，需要将系统中的特权访问进行管控。系统需要对用户层访问内核的特权级系统调用进行限制。仅允许部分高权限应用进行特权操作。具体实现方式是内核spawn第一个用户程序INIT，其包含全部的特权能力，此后，INIT拉起其他应用框架服务，拉起过程中，对各应用框架进行相应的降权操作，为各应用保留必须的特权能力。当应用去调用特权接口时，内核态就会通过进程ID查看当前访问者是否有权限访问目标接口。

总结：操作系统安全的主要研究内容

操作系统为什么会存在安全问题？



操作系统存在哪些安全问题？

操作系统怎么应对安全问题？